

1. Introduction to Data Protection Law

General Data Protection Regulation (GDPR)

- **Applicability:** The GDPR has been applicable since May 25, 2018.
- **Predecessor:** It replaced Directive 95/46/EG (Data Protection Directive) and the Austrian Data Protection Act 2000.
- **Aim:** To harmonize European regulations on data protection.
- **Reasons for Introduction:**
 - Technological advances.
 - Increased data exchange within the European Single Market.
 - Whistleblower protection, among others.
- **Nature:** The GDPR is technology-neutral and often relies on the "state of the art".
- **Consequences of Violation:**
 - Fines.
 - Compensation claims.
 - Prohibition of processing.
 - Loss of reputation.

Interplay with National Law

- The GDPR is directly applicable EU law.
- However, it contains "opening clauses" that allow Member States to enact specific national provisions.
- **Example:** In Austria, the Data Protection Act ("Datenschutzgesetz") and the Research Organization Act ("Forschungsorganisationsgesetz", FOG) utilize these opening clauses.

2. Scope of Application

Material Scope (What is covered?) The GDPR applies to:

1. Automated Processing: Processing of personal data wholly or partly by automated means.
2. Non-Automated Processing: Processing other than by automated means only if the data forms part of a filing system or is intended to form part of a filing system.

Territorial Scope (Where does it apply?)

1. Establishment Principle:

- The GDPR applies to processing in the context of the activities of an establishment of a controller or processor in the Union.
- It does not matter whether the processing takes place in the Union or not.

2. Marketplace / Minimum Contacts Principle:

- The GDPR applies to controllers or processors not established in the Union if they process the data of subjects who are in the Union, provided the activities relate to:

- Offering goods or services to data subjects in the Union (irrespective of whether payment is required). Example: A US online shop available in the German language and Euro currency.

- Monitoring behavior as far as it takes place within the Union. Example: Trackers.

3. Definitions: Personal Data

Definition

- Any information relating to an identified or identifiable natural person ('data subject').
- An identifiable person is one who can be identified, directly or indirectly, by reference to:
 - A name.
 - An identification number.
 - Location data.
 - An online identifier.
 - Factors specific to physical, physiological, genetic, mental, economic, cultural, or social identity.

Classification of Data

1. "Simple" Personal Data: Examples include name, date of birth (dob), address, ZIP code, income, profession.

2. Special Categories of Personal Data (Sensitive Data):

- Racial or ethnic origin.
- Political opinions.
- Religious or philosophical beliefs.
- Trade union membership.
- Genetic data.
- Biometric data (for the purpose of uniquely identifying a person).
- Data concerning health.
- Data concerning a person's sex life or sexual orientation.

Notable Exceptions (Where GDPR does NOT apply)

1. Anonymized Data: Aggregated data that cannot be tracked back to an individual with reasonable effort. Parameters for anonymization include:

- Technology available at the time.
- Costs of identification.
- Time necessary for identification.

2. Deceased Persons: The GDPR only applies to living natural persons.

3. Legal Persons: Data of companies (LLC, PLC, etc.) is not covered.

- Caveat: This exception applies only to the data of the legal entity itself (e.g., company name). Employees (CEO, CFO, CTO) are natural persons, so their data is protected.

4. Definitions: Processing

Definition Any operation performed on personal data, whether automated or not. Examples include:

- Collection, recording, organization, structuring, storage.
- Adaptation, alteration, retrieval, consultation, use.
- Disclosure by transmission, dissemination, or making available.
- Alignment, combination, restriction, erasure, destruction.

Processing in AI Contexts

- Development Stage: Acquisition of non-anonymized training data, training of neural networks, scientific research.
- Deployment Stage: Gathering non-anonymized live data, transforming data (e.g., segmentation), feeding neural networks, deriving decisions.
- Example scenarios:
 - Collection of training data by a research facility.

- Structuring training data by a processing company to train a neural network.
 - Recording live sensor data by a hospital to classify diseases.
-

5. Roles: Controller vs. Processor

Controller

- The entity that determines the purposes and means of the processing of personal data.

Processor

- The entity that processes personal data on behalf of the controller.

Processing Agreement (Art 28 GDPR) A contract is required between Controller and Processor. It must stipulate that:

- Processing is only allowed based on documented instructions from the controller.
 - Persons authorized to process data are committed to confidentiality.
 - All technical and organizational measures (Art 32) are taken.
 - The processor assists the controller (e.g., with data subject rights, data breaches, DPIA).
 - Data is deleted or returned after service ends.
 - The processor allows inspections by the controller.
-

6. Principles of Processing (Art 5 Para 1)

The controller is accountable for ensuring these principles are met:

1. Lawfulness, fairness, and transparency.
2. Purpose limitation.
3. Data minimization.
4. Accuracy.
5. Storage limitation.
6. Integrity and confidentiality.

7. Lawfulness of Processing (Legal Bases)

For "Simple" Personal Data (Art 6 Para 1) Processing is lawful if one of the following applies:

- Consent.
- Performance of a Contract.
- Legal Obligation.
- Protection of Vital Interests of the data subject.
- Task carried out in the Public Interest or exercise of official authority.
- Legitimate Interests pursued by the controller or a third party.

For Special Categories of Data (Art 9 Para 2) Processing is generally prohibited unless an exception applies:

- Explicit Consent.
- Obligations/rights in employment, social security, or social protection law.
- Protection of Vital Interests (if the subject is incapable of giving consent).
- Processing by certain non-profit organizations (foundations/associations).
- Data manifestly made public by the data subject.

- Establishment, exercise, or defense of legal claims.
- Reasons of substantial public interest.
- Purposes for individual health or public health.
- Archiving purposes in the public interest, scientific/historical research, or statistical purposes.

8. Data Protection Officer (DPO)

When is a DPO mandatory?

- If core activities require regular and systematic monitoring of data subjects on a large scale.
- If core activities involve processing special categories of data or criminal conviction data on a large scale.

Position and Duties

- Must be independent and qualified.
- Reports only to the highest management level.
- Acts as a contact point for data subjects and the Data Protection Authority.
- Can be internal or external.
- Tasks: Inform/advise the organization, monitor compliance, and provide advice on Data Protection Impact Assessments (DPIA).

9. International Data Transmission

General Rule When transferring data to a third country (e.g., transferring customer data from Austria to clouds in Japan, USA, or Nicaragua), strict conditions apply.

Permissibility Conditions A transfer is allowed if:

1. Adequacy Decision: The European Commission states the third country has comparable standards (e.g., Israel).
2. Standard Data Protection Clauses: The controller/processor signs a contract containing specific clauses published by the EU Commission.
3. Specific Situations: E.g., Explicit consent of the data subject.
4. Authority Authorization: The Data Protection Authority allows it.

EU-US Data Transfers

- History: Previous frameworks "Safe Harbor" and "EU-US Privacy Shield" were declared void by the European High Court.
- Current Status: Since July 10, 2023, the EU-US Data Privacy Framework (DPF) applies.
- Certification: Data export is allowed based on the DPF only to US companies that have undergone specific certification.
- Examples of certified companies: Google LLC, Meta Platforms Inc., Intuit (Mailchimp), Amazon.com, Inc..

10. Data Protection Impact Assessment (DPIA)

- Requirement: A DPIA is mandatory if processing (especially using new technologies) is likely to result in a high risk to rights and freedoms.
- Method: Criteria-based evaluation using "Blacklists" (operations requiring DPIA) and "Whitelists" (operations not requiring DPIA).

- Timing: Must be carried out prior to processing.

11. Privacy by Design & Default

Privacy by Design

- Data protection must be considered during the development and deployment of IT systems.
- Requires choosing suitable technical and organizational measures to implement Art 5 principles.

Privacy by Default

- Measures must ensure that only necessary personal data is processed by default.
- Examples: No pre-checked checkboxes for consent; webcams should not have insecure/predefined passwords.

12. Technical and Organizational Measures (TOMs)

Controllers and processors must implement security measures appropriate to the risk.

- Parameters to consider: State of the art, implementation costs, nature/scope of processing, and severity of risks.
- Specific Measures Include:
 - Pseudonymization and Encryption.
 - Confidentiality, Integrity, Availability, and Resilience of systems.
 - Ability to restore access in a timely manner after an incident.

- Process for regularly testing and evaluating the effectiveness of measures.

13. Record of Processing Activities (RoPA)

Both Controllers and Processors must maintain this record.

Controller's Record Content:

- Name/contact of controller, joint controller, representative, and DPO.
- Purpose of processing (e.g., payroll, customer requests, training neural networks).
- Categories of data subjects and personal data.
- Categories of recipients (including those in third countries).
- Transfers to third countries and safeguards used.
- Envisaged time limits for erasure.
- Description of security measures (TOMs).

Processor's Record Content:

- Name/contact of processor, controller, and DPO.
- Categories of processing carried out on behalf of each controller.
- Transfers to third countries.
- Description of security measures.

14. Transparency and Rights

Duty to Inform (Privacy Policy)

- Controllers must provide info to data subjects in a precise, transparent, comprehensible, and easily accessible form using clear/simple language.
- It must be free of charge.
- Scenarios:
 - Art 13: When data is collected from the data subject directly.
 - Art 14: When data is received from a third party.

Rights of Data Subjects Data subjects have the right to:

1. Access.
2. Rectification.
3. Erasure ("Right to be forgotten").
4. Restriction of Processing.
5. Data Portability.
6. Object.
7. Non-Automated Decision-Making.

Right to Non-Automated Decision-Making (Art 22)

- Rule: Subjects have the right not to be subject to a decision based solely on automated processing (including profiling) if it produces legal effects or similarly significantly affects them.
- Exceptions (When it IS allowed):
 1. Necessary for entering into or performance of a contract (e.g., credit checks).
 2. Authorized by Union or Member State law.
 3. Explicit consent of the data subject